

NARRATIVA EXPLICATIVA DEL KIT DE ENCUESTA DREAD

Por qué esta encuesta, para qué sirve y cómo leerla sin perder el hilo

"Los datos son el nuevo petróleo, decían. Pero el petróleo, sin refinar, contamina. Esta encuesta aspira a ser la refinería que convierte la experiencia bruta de los profesionales en conocimiento accionable."

1. EL PROBLEMA QUE NOS TRAJÓ AQUÍ

Hay una paradoja en el corazón de la ciberseguridad española de 2026: los incidentes no paran de crecer —122.223 en 2025, un 26% más que el año anterior—, el marco regulatorio no ha sido nunca tan exigente, el presupuesto nunca tan elevado... y, sin embargo, la sensación generalizada es que vamos siempre un paso por detrás. No porque no se trabaje. Sino porque, con demasiada frecuencia, se trabaja sin medir lo correcto.

El marco DREAD —esa criatura de comienzos de los 2000 que Microsoft tuvo la delicadeza de abandonar justo cuando más falta hacía— lleva décadas vagando por los pasillos de los departamentos de seguridad como ese documento que "todo el mundo conoce" pero "nadie aplica sistemáticamente". Y la razón no es que DREAD sea malo; es que aplicarlo bien requiere algo que escasea más que los analistas de seguridad cualificados: criterio común, escalas acordadas y un lenguaje compartido entre técnicos y directivos.

Esta encuesta nació para hacer un diagnóstico honesto. No para señalar a nadie, sino para entender dónde estamos como ecosistema de seguridad nacional.

2. POR QUÉ DREAD Y NO OTRO FRAMEWORK

La pregunta es legítima. CVSS lleva décadas de ventaja, EPSS es más objetivo, FAIR es más riguroso financieramente, y MITRE ATT&CK tiene la cuota de mercado de una plataforma tecnológica madura. ¿Por qué molestarse con DREAD?

La respuesta tiene tres capas:

Primera capa — La sencillez es una feature, no un bug. Un framework que cualquier directivo puede entender en 10 minutos tiene un valor comunicativo que no debe subestimarse. "Esta amenaza tiene Daño 9 sobre 10 y Explotabilidad 8 porque hay un exploit público" es una frase que un CEO entiende mejor que "el score CVSS v4.0 es 9.1 con vector CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H". DREAD es el lenguaje del riesgo entre personas de distinto perfil técnico.

Segunda capa — DREAD captura lo que CVSS no mide. CVSS evalúa la vulnerabilidad técnica; DREAD evalúa el impacto en el negocio y en los usuarios. La dimensión "Usuarios Afectados" no tiene equivalente directo en CVSS. Para organizaciones con obligaciones bajo NIS2 —donde el impacto en los destinatarios del servicio es el criterio central de "incidente significativo"— esta dimensión es esencial.

Tercera capa — La investigación de 2025-2026 lo ha rejuvenecido. La integración de DREAD con machine learning (Thakur et al., JCOMSS 2026, precisión del 99.91% en clasificación IoT), con lógica difusa (Shabbir et al., 2025), con análisis AHP y con la taxonomía de ataques a LLMs (Zahid et al., 2025) ha transformado lo que era un cuestionario subjetivo en la base de un sistema de scoring cuantitativo moderno. DREAD 2.0 no es el DREAD de los libros de texto de los 2000.

3. CÓMO SE CONSTRUYÓ ESTA ENCUESTA

El diseño siguió una lógica concéntrica de cinco fases:

Fase 1 — Revisión de literatura y fuentes primarias

Se consultaron y analizaron las siguientes fuentes principales:

- **INCIBE:** Balance de Ciberseguridad 2025 (datos nacionales de incidentes)
- **CCN-CERT:** Informe IA-04/24 sobre ciberamenazas y tendencias 2024
- **ENISA:** Threat Landscape 2025 y CTL Methodology (agosto 2025)
- **JCOMSS:** Thakur et al. (2026) — Marco híbrido STRIDE-DREAD con ML
- **University of Waikato:** Zahid et al. (2025) — DREAD aplicado a ataques sobre LLMs
- **Wiley Risk Analysis:** Del-Real et al. (2025) — Gobernanza de la ciberseguridad en España 2035
- **Anteproyecto LCGC (enero 2025):** Nueva arquitectura institucional española (CNCS)
- **NAIST (Japón, 2025):** Tesis doctoral sobre contenedores y Fuzzy DREAD
- **Shieldworkz (2026):** DREAD aplicado a entornos OT petroquímicos

Fase 2 — Identificación de dimensiones de análisis

A partir de la revisión, se identificaron 9 dimensiones de análisis:

1. Adopción y conocimiento del marco (Bloque 1)
2. Madurez en cada indicador DREAD (Bloques 2–6)
3. Automatización y herramientas (Bloque 7)
4. Integración con otros frameworks (Bloque 8)
5. Infraestructura crítica y escala nacional (Bloque 9)
6. Cultura y recursos humanos (Bloque 10)
7. Tendencias prospectivas (Bloque 11)
8. Perfil organizativo (Bloque 0)
9. Profundidad cualitativa (Bloque 12)

Fase 3 — Redacción de ítems

Cada ítem fue redactado siguiendo los principios del diseño de encuestas de alta calidad:

- **Preguntas claras y sin doble interpretación:** cada pregunta tiene un único objeto de medición
- **Opciones exhaustivas y mutuamente excluyentes** donde el formato lo permite
- **Normalización del "no" como respuesta válida:** se evita presionar hacia respuestas afirmativas
- **Anclajes conductuales en las escalas:** las opciones de respuesta incluyen ejemplos concretos para reducir la ambigüedad
- **Progresión cognitiva:** los bloques avanzan de lo general (conocimiento) a lo específico (métricas por dimensión) y de lo descriptivo a lo prospectivo

Fase 4 — Diseño del tono

Por decisión explícita del equipo de investigación, la encuesta adopta un tono que combina rigor metodológico con una ligera irreverencia literaria. La razón es funcional: un instrumento que aburre, obtiene respuestas mecánicas. Uno que invita a pensar, obtiene respuestas reflexivas. Los encabezados de bloque con citas (reales o apócrifas) sirven como anclajes cognitivos que activan la reflexión antes de responder.

Fase 5 — Mapeo normativo y construcción del IGM-DREAD

Cada bloque y cada pregunta clave fue mapeada a los requisitos normativos aplicables (ver documento D del Kit) y se diseñó el sistema de cálculo del Índice Global de Madurez DREAD (IGM-DREAD), cuya fórmula y pesos están documentados en la Guía Metodológica (documento B) y en la Plantilla Excel (documento E).

4. CÓMO LEER LOS RESULTADOS

4.1 El IGM-DREAD no es una puntuación de calificación

El IGM-DREAD mide madurez, no bondad. Una organización con IGM = 2.0 no es "mala en ciberseguridad"; es una organización que está al principio de un camino, con las acciones de mejora muy bien identificadas. Una organización con IGM = 4.5 tampoco es "perfecta"; es una organización que ha superado los obstáculos iniciales y se enfrenta ahora a los retos de la optimización y la innovación.

4.2 Los perfiles de dimensión importan tanto como el índice agregado

Un perfil D=5, R=5, E=5, A=1, Disc=5 (IGM ponderado $\approx$ 4.0) es cualitativamente muy distinto de un perfil D=4, R=4, E=4, A=4, Disc=4 (IGM = 4.0 también). El primer perfil tiene un punto ciego crítico en la dimensión de Usuarios Afectados —precisamente la más relevante para el cumplimiento NIS2. Las puntuaciones por dimensión revelan más que el índice agregado.

4.3 El sector lo explica todo (y nada)

Se espera que las organizaciones del sector financiero y la Administración Pública muestren mayor madurez en promedio, simplemente porque llevan más tiempo bajo presión regulatoria. Comparar sin ajustar por sector es la forma más segura de malinterpretar los datos. Siempre contextualice las puntuaciones dentro del estrato sectorial.

4.4 Las preguntas abiertas son el oro del análisis

Las respuestas al Bloque 12 —la lección aprendida, el mayor obstáculo, la propuesta de mejora— suelen ser las que revelan lo que los números no pueden: las tensiones organizativas, los liderazgos bloqueantes, las innovaciones emergentes no capturadas por la escala cuantitativa. Invierta tiempo en el análisis cualitativo.

5. LO QUE ESTA ENCUESTA NO PRETENDE

Por honestidad metodológica —y para no decepcionar a nadie con expectativas desproporcionadas:

- No es una auditoría: los resultados son autoevaluaciones, no verificadas externamente. El sesgo de deseabilidad social existe.
- No certifica nada: un IGM-DREAD alto no equivale a conformidad con ENS, NIS2 o DORA.
- No establece rankings de organizaciones: los resultados se publicarán siempre de forma agregada.
- No reemplaza al threat model: DREAD puntúa amenazas; esta encuesta mide si los procesos de scoring existen y cómo de maduros son.

6. EL MOMENTO ES AHORA: POR QUÉ 2026

España está en un punto de inflexión histórico en materia de ciberseguridad. El Centro Nacional de Ciberseguridad (CNCS) está naciendo. La transposición de NIS2 avanza. La inversión de 1.157 millones de euros del Plan Nacional se está desplegando. El Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad de enero de 2025 redibuja el mapa institucional.

En este contexto, disponer de datos empíricos sobre el estado real de la evaluación de riesgos en las organizaciones españolas no es un lujo académico. Es el insumo que el CNCS, el CCN-CERT, el INCIBE y el legislador necesitan para tomar decisiones de política pública fundamentadas. Y es el espejo en el que cada organización puede verse antes de que lo haga el regulador.

Porque, como nos recuerda con cierta melancolía la teoría de la seguridad: *no saber que no sabes es, con diferencia, el estado más peligroso de todos.*

Kit de Encuesta DREAD · Narrativa Explicativa v1.0 · Abril 2026

Para más información sobre la metodología de investigación, consúltase el documento B (Guía Metodológica)